

Security+ 2.4 · DNS Attacks

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4 — DNS Attacks (8:57)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: DNS (the network's phonebook) is vulnerable to spoofing/cache poisoning (fake response stored in resolver cache), domain hijacking (domain stolen at registrar), URL hijacking/typosquatting (registering 'goggle.com'), and DNS tunneling (hiding data in DNS queries for exfiltration). Defenses include DNSSEC (signs records), monitoring for similar domains, and DNS filtering.

High-Yield Core Concepts Tested on Exam

- DNS spoofing/cache poisoning: fake response stored in resolver cache
- Typosquatting: registers domain with typo (rn/m, 0/o) — used for phishing
- DNS tunneling: exfiltrates data hidden in DNS queries
- Domain hijacking: attacker gains control of domain at registrar

Exam Tips & Classic Scenarios

- 'fake DNS response directs user to attacker server' = DNS spoofing/poisoning
- 'registers domain similar to legitimate one' = typosquatting
- 'data hidden in DNS queries' = DNS tunneling
- 'domain registration transferred without authorization' = domain hijacking

Typical Exam Scenario: Scenario: 'A user types the wrong domain and lands on a phishing site' = typosquatting/URL hijacking.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — DNS Attacks)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An attacker uses RFID to clone employee badges and access restricted areas. What type of physical attack is this?

- A)** Tailgating
- B)** Shoulder surfing
- C)** Credential cloning
- D)** Dumpster diving

2. Corporate scenario (DNS Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'DNS spoofing/cache poisoning: FALSE response cached'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: DNS spoofing/cache poisoning: FALSE response cached...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

3. Corporate scenario (DNS Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Typosquatting: registers a domain with a typo (rn/m, 0/o) — phishing'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Typosquatting: registers a domain with a typo (rn/m, 0/o) — phishing...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (DNS Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'DNS tunneling: exfiltrates data hidden in DNS queries'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: DNS tunneling: exfiltrates data hidden in DNS queries...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (DNS Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'fake DNS response directs user to attacker server' = DNS spoofing/poisoning.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'fake DNS response directs user to attacker server' = DNS spoofing/poisoning...
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (DNS Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'registers domain similar to legitimate one' = typosquatting'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'registers domain similar to legitimate one' = typosquatting...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (DNS Attacks): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 2.4) exam, an analyst evaluates the following technical requirement: 'Scenario: 'user types wrong domain and lands on phishing site' = typosquatting/URL hijacking.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Scenario: 'user types wrong domain and lands on phishing site' = typosquatting/URL hijacking.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (DNS Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'DNS spoofing/cache poisoning: FALSE response stored in cache'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: DNS spoofing/cache poisoning: FALSE response stored in cache
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (DNS Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Typosquatting: registers a domain with a typo (rn/m, 0/o) — phishing'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Typosquatting: registers a domain with a typo (rn/m, 0/o) — phishing...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (DNS Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'DNS tunneling: exfiltrates data hidden in DNS queries'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: DNS tunneling: exfiltrates data hidden in DNS queries...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) C — Credential cloning.

✓ **Why it's correct:** The correct answer is 'Credential cloning'. Credential cloning occurs when an attacker copies the data from an access card (such as RFID badges or proximity cards) to another device, allowing unauthorized access. In the scenario, using RFID to copy the badge signal and replicate it onto a blank card is a classic example of physical credential cloning. CompTIA Security+ covers physical attacks and countermeasures, such as using encrypted cards or mutual authentication to prevent cloning.

✗ **Why the others are wrong:**

- *Tailgating:* Tailgating is the practice of physically following an authorized person through a secure door without using one's own credentials. It does not involve cloning cards or RFID; it is a passive physical intrusion. The option is incorrect because the scenario describes electronic copying of credentials, not entry by proximity.
- *Shoulder surfing:* Shoulder surfing is direct observation over someone's shoulder to obtain information such as passwords or PINs. It does not involve RFID or badge cloning. The option is incorrect because it is a visual observation technique, not electronic duplication.
- *Dumpster diving:* Dumpster diving is searching through trash for discarded information (documents, media) that could be useful to an attacker. It has no relation to RFID or credential cloning. The option is incorrect because it involves recovering discarded data, not intercepting and copying card signals.

2) B — Implement the corresponding solution: DNS spoofing/cache poisoning: FALSE response cached....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (DNS Attacks): DNS spoofing/cache poisoning: FALSE response cached. DNS cache poisoning involves corrupting a DNS resolver's cache with false information, redirecting users to malicious sites. DNSSEC and cache validation are key mitigations.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

3) B — Implement the corresponding solution: Typosquatting: registers a domain with a typo (rn/m, 0/o) — phishing....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (DNS Attacks): Typosquatting: registers a domain with a typo (rn/m, 0/o) — phishing. Typosquatting is a DNS-based attack in which adversaries register domains that closely resemble legitimate ones (e.g., using visually similar characters like 'rn' for 'm' or '0' for 'o') to deceive users into visiting malicious sites, often for phishing, credential harvesting, or malware distribution. The appropriate control is to implement the corresponding solution, which includes defensive measures such as domain monitoring, user awareness training, and DNS filtering to detect and

block such lookalike domains.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: DNS tunneling: exfiltrates data hidden in DNS queries....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (DNS Attacks): DNS tunneling: exfiltrates data hidden in DNS queries. Attackers encode data within DNS queries and responses to bypass firewalls and exfiltrate sensitive information, often using techniques like base64 encoding in subdomains.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) C — Implement the corresponding solution: 'fake DNS response directs user to attacker server' = DNS spoofing/poisoning....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (DNS Attacks): 'fake DNS response directs user to attacker server' = DNS spoofing/poisoning. DNS spoofing/poisoning involves injecting false DNS records into a resolver's cache or spoofing responses, redirecting users to malicious sites for credential theft or malware distribution.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: 'registers domain similar to legitimate one' = typosquatting....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (DNS Attacks): 'registers domain similar to legitimate one' = typosquatting. Typosquatting is a form of cybersquatting that exploits typographical errors made by users when entering a website address, redirecting them to malicious sites.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) B — Implement the corresponding solution: Scenario: 'user types wrong domain and lands on phishing site' = typosquatting/URL hijacking..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (DNS Attacks): Scenario: 'user types wrong domain and lands on phishing site' = typosquatting/URL hijacking. This attack exploits typographical errors in domain names to redirect users to malicious sites. Mitigations include user awareness training, DNS filtering, and domain monitoring.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) A — Implement the corresponding solution: DNS spoofing/cache poisoning: FALSE response stored in cache.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (DNS Attacks): DNS spoofing/cache poisoning: FALSE response stored in cache. This attack corrupts DNS resolver caches with fraudulent records, redirecting users to malicious sites. Mitigations include DNSSEC, cache locking, and using trusted DNS resolvers.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: Typosquatting: registers a domain with a typo (rn/m, 0/o) — phishing....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (DNS Attacks): Typosquatting: registers a domain with a typo (rn/m, 0/o) — phishing.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: DNS tunneling: exfiltrates data hidden in DNS queries....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (DNS Attacks): DNS tunneling: exfiltrates data hidden in DNS queries. DNS tunneling is a technique where attackers encode data of other protocols or exfiltrate data within DNS queries and responses, often bypassing firewalls. The appropriate control is to implement the corresponding solution, which includes DNS monitoring, filtering, and anomaly detection to prevent data exfiltration via DNS.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.